

ACCORD D'ENGAGEMENT — AUDIT DE SÉCURITÉ

Mastère Cybersécurité 2025-2026 | PHASE Grey Box (Environnement Isolé) Audit Local

1. PARTIES IMPLIQUÉES

Étudiant	Nom : MOMBO DARWIN Promotion : Mastère Cybersécurité 2025-2026 Fonction : Apprenti administrateur systèmes et réseaux
Entreprise	Barkene Domaine : barkene.fr
DSI / RSSI / Tuteur	• ALEXANDRE LITAUDON — Poste : DSI • ANTOINE RODRIGUEZ — Poste : RSSI • ANTONIO MATEUS — Poste : Responsable support IT
Date du document	19 juin 2026

PRÉAMBULE

Faisant suite aux conclusions de la Phase I (Audit externe en mode Black Box) ayant identifié la surface d'attaque périphérique, le présent accord encadre la Phase II de l'audit. L'objectif est de simuler un scénario réaliste de compromission interne (vol de machine ou accès initial via un équipement tiers introduit sur le réseau). Cette évaluation permettra d'analyser les chemins d'élévation de privilèges au sein du réseau d'entreprise et d'étudier les corrélations avec les éléments Black Box.

ARTICLE 1 : OBJECTIFS ET SCÉNARIO DE L'AUDIT

- **Scénario de test** : Simulation du vol ou de la compromission d'un poste de travail.
L'Auditeur opère depuis une Machine Virtuelle (VM) dédiée et connectée au réseau. La cinématique de l'attaque consiste à utiliser un compte utilisateur standard (lambda) pour énumérer l'environnement, puis à chercher à capturer ou abuser des secrets du compte

d'administration nommé barkene (compte utilisé pour effectuer la jonction de la VM au domaine).

- **Analyse de corrélation** : Étude et recoupement des vulnérabilités découvertes en Phase I (Black Box) avec les privilèges internes et les faiblesses structurelles de l'annuaire afin de cartographier la chaîne d'attaque complète de bout en bout.

ARTICLE 2 : PÉRIMÈTRE TECHNIQUE ET CIBLE DE L'AUDIT

Le périmètre d'investigation technique est strictement limité à l'environnement Active Directory de l'organisation. L'unique cible autorisée pour l'ensemble des analyses, énumérations et tests d'élévation de privilèges est définie ci-dessous :

Nom du Domaine AD	Adresse IP (Contrôleur de Domaine)	Nature / Usage
finegil.local	172.21.204.10	Contrôleur de Domaine Principal (AD DC)
finegil.local	172.20.103.11	Contrôleur de Domaine Secondaire / Réplication

Les tests visent l'identification des vecteurs de compromission ou chemins critiques locaux et réseaux permettant d'élever ses privilèges au sein de ce domaine spécifique. Tout outil, scan ou requête ciblant un autre domaine ou sous-domaine non inclus dans ce tableau est formellement exclu du présent mandat.

ARTICLE 3 : MATRICE ET CARTOGRAPHIE DES OUTILS UTILISÉS

Afin de garantir une transparence totale vis-à-vis des équipes de la DSI et du RSSI, l'ensemble des outils techniques mis en œuvre par l'Auditeur au cours de la simulation est précisément listé, justifié et circonscrit ci-après :

Nom de l'Outil	Objectif Opérationnel	Mode d'Exécution / Impact
PingCastle	Évaluation automatique du niveau de hardening et de maturité du domaine finegil.local.	Exécution locale sur la VM d'audit. Requêtes LDAP légitimes et non-intrusives en lecture seule. Impact nul sur la production.

SharpHound / BloodHound	Collecte de données et cartographie sous forme de graphes des relations AD (utilisateurs, groupes, ACL, sessions).	Exécution locale (collecteur SharpHound). Requêtes LDAP massives en lecture seule sur l'annuaire. Aucun impact sur l'intégrité des objets.
Outils d'énumération locale (Built-in)	Vérification des droits du profil utilisateur lambda et des configurations de la VM d'audit locale.	Commandes natives Windows (whoami, net user, systeminfo, cmdlets PowerShell de base). Impact nul.
Scripts d'analyse de secrets (ex: Mimikatz / LSASS)	Démonstration théorique d'abus de privilèges ou recherche de secrets liés au compte admin barkene.	Strictement restreint à la mémoire de la VM locale de test non managée. Aucun outil offensif déployé sur les contrôleurs de domaine.

ARTICLE 4 : LOGISTIQUE ET SÉCURITÉ DE L'ENVIRONNEMENT DE TEST

- **Statut de l'environnement (VM) :** L'ensemble des tests sera exécuté depuis une machine virtuelle (VM) dédiée et connectée au réseau de l'entreprise. Conformément au scénario de compromission par un équipement tiers ou externe, cette machine virtuelle est totalement dépourvue de l'agent EDR SentinelOne.
- **Absence d'alertes locales :** L'exécution des outils s'effectuant localement sur cette VM non managée, aucune alerte de blocage ou de détection locale par un EDR ne viendra perturber la collecte technique.
- **Outils d'audit AD autorisés :** L'usage des solutions répertoriées à l'Article 3 est expressément validé sous réserve de l'utilisation exclusive des identifiants du compte utilisateur standard assigné à la simulation.

ARTICLE 5 : RÈGLES D'ENGAGEMENT

- **Énumération et lecture AD :** La collecte de données Active Directory via requêtes LDAP standards ou via les outils autorisés (PingCastle, SharpHound) sur le domaine finetil.local doit s'effectuer sans altération ni modification des objets de l'annuaire.
- **Cadre d'Élévation de Privilèges :** La recherche de chemins d'élévation de privilèges vise exclusivement à démontrer la faisabilité technique de compromission et d'abus du compte d'administration barkene. Toute exploitation de vulnérabilité technique critique (exploit de

type déni de service, modification définitive de schéma, etc.) requiert une validation écrite préalable du RSSI ou de la DSI.

- **Non-Perturbation** : L'Auditeur veillera à ce que l'exécution des outils d'analyse ne perturbe pas la disponibilité de l'infrastructure ni les flux de production.

ARTICLE 6 : MÉTHODOLOGIE ET RÉFÉRENTIELS

- **PTES (Penetration Testing Execution Standard)** : Encadrement des phases de modélisation des menaces et d'analyse des vulnérabilités.
- **MITRE ATT&CK** : Cartographie des techniques utilisées pour l'accès initial, la découverte (Discovery) et l'élévation de privilèges (Privilege Escalation).
- **CVSS v4.0** : Évaluation standardisée de la sévérité des configurations défectueuses ou vulnérabilités locales/domaines identifiées.

ARTICLE 7 : CONFIDENTIALITÉ, TRAÇABILITÉ ET RÉVOCATION

Les données d'architecture collectées sont classées comme Strictement Confidentielles. L'Auditeur consigne de manière traçable l'ensemble des requêtes, outils et créneaux horaires d'intervention. Conformément à la charte de l'entreprise, cet accord peut être suspendu ou révoqué instantanément par le tuteur, le RSSI ou la DSI en cas de nécessité opérationnelle.

ARTICLE 8 : TRAÇABILITÉ & CONFIDENTIALITÉ

- Documenter toutes les actions effectuées avec horodatage, outil utilisé, cible et résultat.
- Conserver les logs et captures d'écran comme preuves de la démarche d'audit.
- Ne communiquer les résultats qu'au tuteur entreprise et au jury de soutenance.
- Anonymiser ou supprimer toute donnée sensible à l'issue du mémoire.

ARTICLE 9 : DURÉE & RÉVOCATION

- **Durée** : Le présent accord est valable pour la durée du projet de mémoire (jusqu'à la soutenance).
- **Révocation** : Le tuteur/RSSI/DSI peut révoquer cet accord à tout moment par notification écrite. En cas de révocation, l'étudiant(e) cesse immédiatement toute activité d'audit.

Signatures

En signant ce document, les parties reconnaissent avoir lu, compris et accepté l'ensemble des dispositions du présent accord.

Tuteur entreprise	RSSI	DSI
Nom & Prénom : Antonio MATEUS Fonction : Responsable SUPPORT IT Date : _____ Lieu : _____	Nom & Prénom : Antoine RODRIGUEZ Fonction : RSSI Date : _____ Lieu : _____	Nom & Prénom : Alexandre LITAUDON Fonction : DSI Date : _____ Lieu : _____

Signature de l'étudiant(e):

Nom & Prénom : MOMBO DARWIN Fonction : Apprenti administrateur systèmes et réseaux
Date : 19/06/2026 Lieu : Neuilly sur Seine